

CAMS Exam Preparation

Part C: Building an Anti-Financial Crime Compliance Program (30 percent of Exam)

Advanced AML Training Framework

Domain 6: 30 percent of CAMS Exam — 110+ Slides — Governance, Controls, Investigations and Testing

Core Concept

A foundational governance model ensuring separation between risk-taking, risk oversight, and independent assurance.

Line	Who	Primary Role
First Line	Business ops, RMs, tellers, loan officers	Own and manage risk; identify anomalies; complete initial CDD; escalate to compliance
Second Line	Compliance Dept, BSA Officer, MLRO	Oversee risk; set rules; monitor First Line; investigate; file SARs
Third Line	Internal Audit, external auditors	Independent assurance; audit First and Second Lines; report to Board

[RED FLAG: Golden Rule: No single line should both DESIGN and TEST the same controls.]

[FOCUS] Exam tests whether you can identify independence violations across all three lines.

First Line (Business Operations) - What They MUST Do

The First Line is the front door of AML defense. They interact with customers directly.

Specific Duties:

- Complete initial CIP
- Assess expected activity profile
- Identify unusual transactions
- Escalate concerns to compliance
- Respond to compliance RFIs
- Maintain customer records
- Update changes in customer status

Common Red Flags to Spot:

- Reluctance to provide ID
- Unusual transaction patterns
- Structuring cash deposits
- Changes without explanation
- Inconsistent narratives
- Third-party transactions
- Reluctance to explain source

[RED FLAG: Critical: First Line cannot close alerts or make SAR decisions. That is Second Line authority.]

[SCENARIO] RM Tells Analyst to Close Alert Based on Personal Knowledge A relationship manager has known a corporate client for 12 years. The client suddenly makes weekly cash deposits of \$9,500 - just below the \$10,000 CTR threshold. The RM tells compliance: I have known this customer for over a decade. He is trustworthy. Just close the alert. The analyst closes the alert without independent review, documentation, or supervisor consultation.

How to Analyze:

- 1 First Line's job: IDENTIFY and ESCALATE - not investigate or close
- 2 Second Line's job: INVESTIGATE independently
- 3 The deposit pattern (\$9,500 weekly) is structuring
- 4 Closing without documentation violates AML program requirements

[TRAP] RM's long relationship is NOT sufficient evidence to close an alert. [CORRECT]
Compliance must conduct independent investigation with documented evidence.

Second Line (Compliance) - Core Duties

The Second Line must operate independently from the First Line and have authority to override business decisions.

Core Duties:

- Design AML policies
- Conduct transaction monitoring
- Investigate alerts
- Make SAR filing decisions
- File SARs with FIU
- Provide training
- Conduct EDD
- Maintain risk assessment
- Respond to law enforcement
- Report to Board

Independence Requirements:

- Cannot report to business lines
- Direct Board access
- Override business decisions
- Sufficient staffing
- No commercial pressure
- Access to all information
- Independent budget

[RED FLAG: Commercial importance of a client is NEVER a valid reason to delay or avoid SAR filing.]

[SCENARIO] Analyst Closes Alert Without Investigation An analyst reviews an alert for a restaurant customer with 23 cash deposits between 8,400 and 9,800 over 45 days. The analyst writes: Restaurant business. Cash is normal. No SAR needed. The analyst closes without: daily sales logs, prior period comparison, supervisor consultation, or any documentation.

How to Analyze:

- 1 23 deposits just below \$10,000 = structuring indicator
- 2 Structuring is a federal crime regardless of funds origin
- 3 The analyst assumed legitimacy without verification
- 4 No documentation = no investigation occurred

[TRAP] Analyst used reasonable business judgment based on industry. [CORRECT] Analysts must obtain supporting documentation and document all investigative steps. Assumptions are not investigations.

Internal Audit - What They CAN and CANNOT Do

Audit independence is absolutely critical to program credibility.

Audit CAN Do	Audit CANNOT Do
Test effectiveness of controls	Design or build controls
Recommend improvements	Operate monitoring systems
Report findings to Board	Make SAR decisions
Review sample of alerts	Approve customer relationships
Assess policy compliance	Perform ongoing monitoring
Evaluate training	Conduct EDD on customers

[RED FLAG: Most Common Violation: Audit helping to design scenarios THEN auditing those same scenarios.]

[SCENARIO] Audit Designs Controls Then Tests Them Compliance lacks technical expertise. CCO asks Internal Audit for help. Audit spends 3 months co-designing 14 new monitoring scenarios. Six months later, the same audit team tests the system and finds all 14 scenarios effective.

How to Analyze:

- 1 Audit's role is to TEST, not DESIGN
- 2 Designing controls makes Audit part of Second Line
- 3 Auditors cannot objectively test their own work
- 4 The audit findings are unreliable

[TRAP] Scenarios were effective, so no violation. OR CCO appropriately sought help.
[CORRECT] Audit must remain independent. Use external consultants or different internal team with no design involvement.

Board Oversight - Ultimate Accountability

The Board is ultimately accountable for the AML program. Regulators hold the Board responsible.

Board MUST:

- Approve initial AML program
- Approve material changes
- Appoint BSA Officer
- Receive regular updates
- Be informed of deficiencies
- Hold management accountable
- Review audit findings
- Ensure adequate resources

Board DOES NOT:

- File SARs
- Review KYC files
- Monitor daily alerts
- Conduct investigations
- Make SAR decisions
- Perform testing
- Approve transactions

[RED FLAG: Board approval is required for the AML program. CCO cannot approve their own program.]

[SCENARIO] Management Withholds Information from Board Compliance discovers a 14-month monitoring gap affecting \$340 million in wires. Senior management decides not to inform the Board because the issue is operational and will be fixed within 90 days.

How to Analyze:

- 1 14-month gap affecting \$340 million is MATERIAL
- 2 Material deficiencies MUST be reported to Board immediately
- 3 Management cannot filter or delay reporting
- 4 Board needs this information for oversight

[TRAP] Senior management has authority to decide what reaches the Board. [CORRECT]
Board must be informed of material deficiencies. Management cannot withhold this information.

[SCENARIO] CCO Implements Policy Without Board Approval CCO drafts revised AML policy. Legal reviews and approves. CCO implements without presenting to Board. CCO argues: I am the designated BSA Officer with authority to implement policies. Board approval is unnecessary.

How to Analyze:

- ❶ Board must approve AML program under BSA
- ❷ Material changes require Board approval
- ❸ CCO implements, does not have final approval
- ❹ Policy is not effective without Board approval

[TRAP] CCO has delegated authority to implement policies. [CORRECT] Board must approve AML program and material changes. CCO implements Board-approved program but lacks final approval authority.

Senior Management - Execution and Accountability

Senior management executes the Board-approved program and is accountable to the Board.

Senior Management MUST:

- Implement Board-approved program
- Allocate sufficient resources
- Ensure timely SAR filings
- Respond to audit findings
- Report material issues to Board
- Appoint qualified staff
- Ensure training effectiveness

Senior Management CANNOT:

- Veto SARs for commercial reasons
- Withhold information from Board
- Retaliate against whistleblowers
- Operate without Board approval
- Delegate accountability
- Ignore audit findings

[RED FLAG: Senior management faces personal regulatory risk for AML failures, including fines and imprisonment.]

Required Scope - Operational Effectiveness

Independent testing is one of the five mandatory BSA pillars. Must test OPERATIONAL effectiveness.

Area	Specific Testing Procedures
Transaction Monitoring	Test thresholds using historical SARs; calculate false negative rate; validate alert logic
Sanctions Screening	Test fuzzy logic; validate name matching; review override decisions
CDD/KYC	Review high-risk samples; verify UBO identification; test EDD documentation
SAR Filing	Review timeliness; assess quality; test escalation; validate no tipping-off
Training	Assess role-based content; test completion rates; evaluate effectiveness
Governance	Review Board approvals; test independence; review escalation documentation

[RED FLAG: Not sufficient: Only reviewing policies without testing transactions.]

[SCENARIO] Audit Discovers 77 Percent False Negative Rate Auditor tests system by running 500 historical SAR cases through current system. 387 of 500 (77 percent) would NOT generate an alert under current thresholds. Compliance director argues this is acceptable because bank already reviews 22,000 alerts per month.

How to Analyze:

- 1 77 percent false negative rate is EXTREMELY high
- 2 System would miss over three-quarters of confirmed suspicious activity
- 3 Operational burden is NOT a valid excuse
- 4 Regulators prioritize detection over efficiency

[TRAP] High alert volume justifies maintaining current thresholds. [CORRECT] System must be effective first. Document deficiency, create remediation plan, recalibrate thresholds.

Qualification Requirements

The tester must meet specific independence and expertise requirements.

Acceptable	NOT Acceptable
Internal Audit (if independent)	Compliance testing itself
External Audit Firm	Audit that designed controls
Third-Party Consultant	Former compliance staff who designed policies
Independent consultant	Business line employees
No prior involvement	Vendors who built the system

Requirements:

- Independence: No involvement in designing or operating controls
- Expertise: AML/CFT knowledge and qualifications
- Objectivity: No conflicts of interest
- Reporting: Reports to Board or Audit Committee, not CCO

[SCENARIO] Tester Previously Worked in Compliance Bank hires external consulting firm for AML audit. Firm assigns individual who was bank's BSA Officer until 8 months ago. This individual personally designed several policies now being audited. CCO sees no issue because consultant is external.

How to Analyze:

- 1 Independence is about the PERSON, not just the firm
- 2 Person who designed controls cannot audit those controls
- 3 8-month separation does NOT restore objectivity
- 4 Firm should assign different personnel

[TRAP] Consultant is external, so independence is automatically satisfied. [CORRECT]
Individual tester must have no prior involvement. Assign different team member.

[SCENARIO] Audit Reports to CCO for Approval Audit completes annual AML audit and issues draft report identifying deficiencies. Audit manager provides draft to CCO for approval before finalizing. CCO requests that critical findings be removed. Audit manager agrees. Final report shows no deficiencies.

How to Analyze:

- 1 Audit must report findings directly to Board
- 2 Management cannot approve or edit audit findings
- 3 Removing findings destroys audit independence
- 4 Final report is unreliable

[TRAP] CCO is responsible for AML program and should review findings for accuracy.

[CORRECT] Audit findings must be reported directly to Board without management filtering. CCO may receive copy but cannot control content.

How Often Must Testing Be Performed?

Frequency depends on risk profile, but at least annually for most institutions.

Risk-Based Frequency Considerations:

- High-risk institutions: Semi-annual or quarterly testing recommended
- Medium-risk institutions: Annual testing is standard
- Low-risk institutions: Annual testing is minimum, but may be less intensive
- Material changes: Trigger interim testing outside normal cycle
- Regulatory findings: May require more frequent testing

Trigger Events for Interim Testing:

- New high-risk products or services
- Significant customer base growth
- Merger or acquisition
- Regulatory enforcement action
- Material system changes
- Emergence of new typologies
- Known control deficiencies

[RED FLAG: Annual is minimum, not maximum. Material changes require interim testing.]

The Core Calibration Trade-Off

Every AML monitoring system faces this fundamental decision.

Term	Definition	Risk
False Positive	Legitimate activity triggers alert	Wasted analyst time; operational inefficiency; analyst fatigue
False Negative	Suspicious activity generates no alert	MISSED criminal activity; direct AML deficiency; enforcement risk

[RED FLAG: Which is worse? FALSE NEGATIVES are significantly worse.] [NOTE:

Regulator Priority: Detection effectiveness & operational efficiency.]

[SCENARIO] Director Raises Thresholds by 250 Percent Bank generates 8,000 alerts/month with 96 percent false positives. Director orders all thresholds raised by 250 percent to reduce costs. Team leader warns this will increase false negatives. Director replies: Any missed activity is acceptable as long as we still file some SARs.

How to Analyze:

- ❶ 250 percent increase is extreme and arbitrary
- ❷ Many suspicious transactions will fall below thresholds
- ❸ Director prioritizing cost over effectiveness
- ❹ Regulators will view as material deficiency

[TRAP] Director correctly managing operational efficiency under risk-based approach.

[CORRECT] Raising thresholds must be data-driven. Validate new thresholds still detect known typologies. Effectiveness cannot be sacrificed.

[SCENARIO] System Generates 50,000 Alerts Per Month Bank sets thresholds very low to catch everything. System generates 50,000 alerts/month. Team has 5 analysts, each can review 200 alerts/month. Backlog grows to 40,000 uninvestigated alerts. Director argues lower thresholds are always better.

How to Analyze:

- 1 Team can only review 1,000 alerts/month
- 2 49,000 alerts/month are never reviewed
- 3 Unreviewed alerts provide zero detection value
- 4 Bank must increase staffing OR recalibrate

[TRAP] Lower thresholds always better because they catch more activity. [CORRECT]
System must be calibrated so team can review all alerts. Unreviewed alerts are a control failure.

[SCENARIO] Model Performance Degrades Over 3.5 Years Bank deployed ML model January 2022 with 72 percent precision and 81 percent recall. June 2025 validation shows 51 percent precision and 62 percent recall. Bank introduced new products, volumes up 180 percent, typologies shifted. Model never recalibrated.

How to Analyze:

- 1 Models degrade when behavior/products/typologies change
- 2 3.5 years without recalibration is a significant gap
- 3 Annual recalibration or trigger-based retraining required
- 4 Performance degradation requires immediate remediation

[TRAP] Model still has recall above 60 percent, which is acceptable. [CORRECT] Bank must establish model monitoring and refresh processes. Significant degradation requires recalibration or replacement.

[SCENARIO] Bank Implemented System in 2022, No Updates by Mid-2025 Bank implemented automated transaction monitoring system in January 2022. By mid-2025, bank introduced new products, transaction volumes increased significantly, and financial crime typologies evolved. Recent internal review found system generating less effective results. Bank has not updated or reviewed the system since implementation.

How to Analyze:

- ❶ Systems degrade when products/volumes/typologies change
- ❷ 3.5 years without review is a significant compliance gap
- ❸ Periodic tuning and updates are AML program requirements
- ❹ "Acceptable" performance without adaptation increases risk exposure

[TRAP] Continue using the system since it is still identifying suspicious activity at an acceptable level. [CORRECT] Establish a process to periodically review, tune, and update the monitoring system.

When Must Interim Validation Be Performed?

Annual validation is minimum. Certain events trigger interim validation.

Trigger Events Requiring Interim Validation:

- New high-risk products or services (crypto, correspondent banking, private banking)
- Significant customer base growth (acquisition, organic growth over 25 percent)
- Emerging typologies (sudden increase in specific SAR types)
- Regulatory changes (new requirements or guidance)
- Model performance alerts (vendor notification of degradation)
- Material system changes (new vendor, major upgrade)
- Known control failures (audit findings, regulatory exam findings)
- Geographic expansion (new high-risk jurisdictions)

Documentation Requirements:

- Date of trigger event
- Validation methodology used
- Results of validation testing
- Any threshold adjustments made
- Approval by compliance management
- Board notification for material changes

[RED FLAG: Policies that only require annual validation are deficient without trigger provisions.]

How to Test If Scenarios Are Working

Multiple methods are used to validate scenario effectiveness.

Historical SAR Testing (Back-testing):

- Run historical SAR cases through current scenarios
- Calculate capture rate (percentage that would generate alerts)
- Acceptable capture rate depends on typology but should exceed 70 percent
- Low capture rate indicates over-filtering or scenario decay

Holdout Sample Testing:

- Reserve portion of SAR data not used in development
- Test scenarios on holdout sample to validate performance
- Helps detect overfitting to development data

Scenario and Threshold Tuning:

- Adjust parameters based on testing results
- Document all changes with rationale
- Re-test after changes to validate improvement
- Maintain version control of scenarios

Benchmarking:

- Compare detection rates to industry peers (if data available)
- Use regulatory guidance on expected detection rates
- Consider typology-specific capture rates

Core Concept

A monitoring system is only as good as the data it receives. Missing data = missing alerts.

Critical Controls That Must Exist:

- Reconciliation between source systems and monitoring system (daily or real-time)
- Data completeness and accuracy checks (automated validation rules)
- Error handling and alerting for failed data feeds (no silent failures)
- Regular validation that all required transactions are ingested (sample testing)
- Data lineage documentation (know where each data element comes from)
- Data quality metrics and reporting to management

[RED FLAG: The worst data failure: Silent failure where data is missing but no error messages alert the team.] [FOCUS] Exam tests whether you understand that data quality is a compliance responsibility, not just IT.

[SCENARIO] 34 Percent of Wires Missing for 14 Months Bank's monitoring system relies on daily feeds from 17 upstream systems. Audit reveals that for 14 months, the feed from the international wire system silently failed for 34 percent of all wires. Those transactions never entered monitoring, never generated alerts, never reviewed. Estimated \$340 million in wires not monitored. Failure was technical misconfiguration with no error messages. No reconciliation controls existed to detect the gap.

How to Analyze:

- 1 34 percent missing data = massive monitoring gap
- 2 No alerts for transactions system never received
- 3 Absence of reconciliation controls is foundational failure
- 4 Bank must remediate AND review missed transactions retrospectively
- 5 SARs must be filed for any suspicious activity identified in missed transactions
- 6 Regulators will view this as material deficiency

[TRAP] Misconfiguration was accidental, so no compliance violation occurred. [CORRECT]
Bank must have controls to verify complete data ingestion. 14-month gap requires retrospective review and SAR filing.

Reconciliation Controls - What Must Exist

Banks must be able to prove that all transactions entered the monitoring system.

Reconciliation Methodology:

- Source system transaction count vs. monitoring system intake count (daily)
- Source system total dollar volume vs. monitoring system total volume (daily)
- Hash total comparisons for data integrity
- Exception report for any discrepancies
- Timely resolution of exceptions (24-48 hours)
- Escalation for unresolved exceptions

Common Data Quality Issues:

- Missing transactions (data feed failure)
- Duplicate transactions (processing errors)
- Corrupted data (format issues)
- Delayed data (latency beyond acceptable window)
- Incomplete data (missing required fields)
- Incorrect data (wrong values, mapping errors)

Risk of No Reconciliation:

- Cannot demonstrate monitoring completeness to regulators
- Undetected data gaps may exist for months or years
- Criminal activity may be processed without detection
- Bank may face enforcement action for monitoring failure

[SCENARIO] 12 Percent of Transactions Have NULL Customer ID Monitoring system flags large wire transfers. When analyst investigates, system shows Customer ID: NULL value. Data issue present for 8 months. IT explains that mobile app account openings sometimes fail to populate unique identifier. Approximately 12 percent of transactions cannot be linked to any customer record.

How to Analyze:

- 1 Unlinked transactions cannot be investigated properly
- 2 Bank cannot determine customer risk or conduct CDD
- 3 Data quality failure with direct AML impact
- 4 Cannot file accurate SARs without customer identification
- 5 Root cause must be fixed
- 6 Process needed to identify and investigate orphaned transactions

[TRAP] IT issues are operational and not a compliance concern. [CORRECT] Missing customer identification is material AML deficiency. Fix root cause and develop process for orphaned transactions.

Data Quality Key Performance Indicators

Compliance must monitor and report data quality metrics to management.

Essential Data Quality Metrics:

- Data completeness percentage by source system (target: 99.9 percent+)
- Data timeliness (average latency from transaction to monitoring)
- Data accuracy (error rate in critical fields)
- Reconciliation exception rate and aging
- Number of unlinked transactions
- Number of failed data feeds

Governance Requirements:

- Data quality is shared responsibility (IT, Compliance, Business)
- Compliance must define data requirements for monitoring
- IT must implement controls to meet requirements
- Business must ensure source system data quality
- Regular data quality review meetings
- Escalation path for unresolved data issues
- Board reporting on material data gaps

[RED FLAG: Compliance cannot simply accept whatever data IT provides. Compliance must define requirements.]

Core Concept

Different analysts should reach similar conclusions on similar facts. Wide variation indicates lack of standards.

Required Controls to Ensure Consistency:

- Written adjudication guidelines for each scenario
- Required documentation standards (what must be in every case file)
- Quality assurance reviews of closed alerts (sample testing)
- Calibration sessions to align analyst judgment
- Supervisor approval for certain dispositions
- Appeal process for disputed decisions
- Regular training on adjudication standards

[RED FLAG: Red Flag: One analyst closes 95 percent of alerts as false positives; another escalates 70 percent for the same scenario.] [FOCUS] Exam tests whether you know that standardization is required, not optional.

[SCENARIO] 94 Percent vs. 67 Percent Escalation Rate QA team reviews 200 closed alerts for cash deposit scenario. Analyst A closed 94 percent as false positives with note: Customer is a retailer; cash is normal. Analyst B, reviewing similar accounts for same scenario, escalated 67 percent for further investigation and filed SARs on 22 percent. Neither analyst's file includes supporting documentation. Bank has no written adjudication guidelines for this scenario.

How to Analyze:

- 1 94 percent vs. 67 percent variation is extreme and unacceptable
- 2 Without written guidelines, analysts apply inconsistent standards
- 3 No documentation = bank cannot demonstrate investigations occurred
- 4 Bank needs written guidelines AND QA oversight
- 5 Analyst A may be under-escalating (missing suspicious activity)
- 6 Analyst B may be over-escalating (wasting resources)
- 7 Either way, process is not controlled

[TRAP] Different analysts apply professional judgment differently; variation is acceptable.

[CORRECT] Bank must have written adjudication standards, required documentation, and QA processes.

[SCENARIO] Analyst Closes Alert Based on Assumption Alert flags customer with 23 cash deposits between 8,400 and 9,700 over 45 days. Customer is restaurant owner. Analyst writes: Restaurant business. Cash from customers. No SAR needed. Analyst closes without requesting daily sales logs, comparing to prior periods, checking if pattern changed after new manager hired, or any supporting documentation.

How to Analyze:

- ❶ Deposit pattern is classic structuring indicator
- ❷ Analyst assumed legitimacy without verification
- ❸ No supporting documentation was obtained
- ❹ Alert closed without meaningful investigation
- ❺ Cannot defend this decision in regulatory exam

[TRAP] Analyst used business context to make reasonable judgment. [CORRECT] Analysts must obtain and review supporting documentation. Assumptions without verification do not constitute investigation.

QA Program - Essential Elements

Quality assurance is the check on analyst decision-making.

QA Program Components:

- Sample size: Sufficient to be statistically valid (typically 5-10 percent of alerts)
- Sampling methodology: Random plus targeted (high-risk scenarios, specific analysts)
- QA reviewer independence: Different from original analyst
- QA reviewer qualifications: More experienced than front-line analysts
- Dispute resolution process: Path for disagreement between analyst and QA
- Remediation: Process for correcting errors found by QA
- Trending: Track QA findings over time to identify patterns
- Reporting: QA results reported to compliance management monthly

What QA Reviews:

- Did analyst obtain required documentation?
- Is documentation sufficient to support conclusion?
- Was analysis thorough and logical?
- Was conclusion reasonable based on evidence?
- Were escalation procedures followed?
- Was SAR filed when required?
- Was tipping-off avoided?

[RED FLAG: No QA program = no assurance that analysts are making correct decisions.]

Core Concept

SARs must be filed immediately upon suspicion, regardless of transaction value.

Key Principles:

- Legal standard = REASONABLE SUSPICION (not certainty, not probable cause, not proof)
- No minimum monetary threshold for money laundering suspicion
- Do NOT delay filing to gather more evidence
- Do NOT investigate to point of certainty before filing
- File first, continue investigating if needed
- Cannot consider commercial impact of filing
- Cannot notify customer (tipping-off prohibition)

What Reasonable Suspicion Means:

- More than a hunch, less than probable cause
- Specific articulable facts that suggest possible money laundering
- Based on training, experience, and available information
- Does not require knowledge of underlying predicate offense
- Does not require confirmation that funds are criminal

[RED FLAG: Common violation: We need more evidence before filing. This is incorrect. Reasonable suspicion is enough.]

[SCENARIO] Supervisor Delays SAR Filing for 60 Days Compliance analyst identifies pattern raising reasonable suspicion of money laundering. Supervisor says: We do not have enough evidence yet. Keep investigating and file when you have conclusive proof. Analyst continues investigating for 60 days without filing SAR.

How to Analyze:

- 1 Reasonable suspicion is the legal standard, not proof
- 2 Conclusive proof is NOT required for SAR filing
- 3 Delaying filing is a regulatory violation
- 4 Bank can file SAR and continue investigating
- 5 Supervisor misstated the legal standard
- 6 60-day delay is significant and indefensible

[TRAP] Supervisor correctly wants more evidence to ensure SAR is accurate. [CORRECT]
SAR must be filed immediately upon reasonable suspicion. File first, then continue investigating. Delaying is violation.

[SCENARIO] Teller Tells Customer About Compliance Review Customer asks teller why wire transfer is delayed. Teller says: I am sorry, but our compliance team is reviewing your account for some unusual activity. Customer becomes agitated and closes account. No SAR has been filed yet; investigation is ongoing.

How to Analyze:

- 1 Tipping-off includes disclosing that an investigation EXISTS
- 2 You do NOT need to mention SAR by name to tip off
- 3 Telling customer they are under compliance review IS tipping-off
- 4 Violation occurred even though no SAR filed yet
- 5 Teller should have given neutral response or said nothing

[TRAP] No SAR was filed yet, so no tipping-off occurred. [CORRECT] Tipping-off includes disclosing existence of internal investigation. Train staff not to disclose compliance scrutiny.

[SCENARIO] Two Banks Share SAR Information Under 314(b) Two banks have filed SARs on different individuals who appear to be part of same money laundering network. Both banks have filed FinCEN 314(b) opt-in notifications. BSA Officers meet to share information about suspicious activity.

How to Analyze:

- 1 314(b) permits voluntary information sharing between opted-in institutions
- 2 Sharing is protected by safe harbor from liability
- 3 This is NOT tipping-off because explicitly permitted by law
- 4 Both banks must have filed opt-in notification
- 5 Sharing must be for purpose of identifying ML/TF activity

[TRAP] Sharing SAR information with another bank always constitutes tipping-off.

[CORRECT] 314(b) sharing is lawful exception to tipping-off. Banks that opted in can share information.

[SCENARIO] Analyst Shares SAR Draft with Legal Department Compliance analyst drafts SAR. Before filing, analyst shares draft with bank's legal department for review. Legal department advises on potential legal risks. Analyst then files SAR.

How to Analyze:

- 1 Legal department has legitimate need to know
- 2 Sharing is internal, not external
- 3 SAR remains confidential, not disclosed to customer
- 4 This is standard and permissible practice
- 5 Does not constitute tipping-off

[TRAP] Any sharing of SAR information before filing is tipping-off. [CORRECT] Internal sharing with legal, compliance management, and audit on need-to-know basis is permissible.

Unauthorized Disclosure is a Crime

Disclosing SAR information without authorization carries criminal penalties.

Penalties for Unauthorized Disclosure:

- Criminal fines up to \$250,000 for individuals
- Imprisonment up to 5 years
- Civil penalties for institutions
- Termination of employment
- Professional debarment

Who Can Receive SAR Information:

- FinCEN and other FIUs (by filing)
- Law enforcement (via proper channels)
- Other opted-in 314(b) institutions (limited)
- Legal department (internal need-to-know)
- Compliance management (internal need-to-know)
- Internal Audit (internal need-to-know)
- Board of Directors (oversight)

Who CANNOT Receive SAR Information:

- The customer (tipping-off)
- Customer's attorney (without legal process)
- Media or public
- Other banks not under 314(b)
- Foreign regulators without proper channel

[RED FLAG: SAR confidentiality is absolute except for specific legal exceptions.]

Recordkeeping Requirements for SARs

SARs and supporting documentation must be retained for specific periods.

Retention Requirements:

- SAR filing and all supporting documentation: 5 years from date of filing
- Copy of SAR (confidential file): 5 years
- RFI and customer responses: 5 years
- Documentation of SAR decision: 5 years

What Must Be Retained:

- SAR form itself (if paper filed)
- Copy of electronic filing confirmation
- All transaction data reviewed
- Analyst investigation notes
- Supporting documentation obtained
- Supervisor approval documentation
- RFIs and responses
- Decision to file or not file
- Law enforcement feedback (if any)

Recordkeeping Systems Requirements:

- Secure access (limited to need-to-know)
- Audit trail of who accessed SAR files
- Tamper-proof records
- Ability to produce records upon request
- Backup and disaster recovery

[RED FLAG: Records cannot be deleted until retention period expires, regardless of customer request.]

Core Concept

Financial institutions have a legal obligation to respond to valid law enforcement requests.

Key Principles:

- Comply promptly within specified timeframe
- Maintain internal record of everything produced
- Do NOT notify customer unless subpoena requires disclosure
- Seek legal advice if uncertain about scope or validity
- Do not destroy records after receiving subpoena (legal hold)
- Produce only what subpoena requests (not everything)
- Redact privileged or unrelated information

[RED FLAG: What NOT to do: Destroy records, notify customer to warn them, refuse to comply without legal basis.]

[SCENARIO] Bank Receives Grand Jury Subpoena Bank receives federal grand jury subpoena demanding all account records, wire logs, and signature cards for corporate customer under investigation. Subpoena includes non-disclosure provision prohibiting bank from notifying customer.

How to Analyze:

- 1 Bank must comply with subpoena
- 2 Non-disclosure provision means bank CANNOT tell customer
- 3 Bank must maintain internal record of everything produced
- 4 Bank should not destroy any responsive records
- 5 Legal hold must be implemented

[TRAP] Bank should notify customer so they can respond to subpoena. [CORRECT] Comply promptly, maintain internal records, do not violate non-disclosure provision.

[SCENARIO] Law Enforcement Asks Bank to Keep Account Open Bank filed three SARs on account over six months and decided to close relationship. Before closing, federal agent contacts bank in writing, requesting bank keep account open for additional 90 days for ongoing undercover investigation. Agent says closing would alert subjects.

How to Analyze:

- 1 Bank should generally comply with written LE requests
- 2 Request must be documented in writing
- 3 Senior management approval should be obtained
- 4 Bank should continue enhanced monitoring during extension
- 5 Document decision to keep open or close

[TRAP] Bank must close account immediately regardless of LE request. [CORRECT]
Document request in writing, obtain senior management approval, keep open as requested with enhanced monitoring.

Legal Hold - What Must Be Preserved

Once a subpoena is received, a legal hold suspends normal record destruction.

Legal Hold Process:

- Identify all relevant records (customer files, transaction data, communications)
- Notify all relevant departments (compliance, IT, records management)
- Suspend any scheduled destruction of records
- Preserve records in original format
- Maintain chain of custody
- Document legal hold implementation
- Release hold only after authorized by legal counsel

Common Legal Hold Failures:

- Automated record destruction continues after subpoena
- Relevant departments not notified
- No documentation of hold implementation
- Premature release of hold
- Failure to preserve electronic records (emails, logs)

[RED FLAG: Destroying records after receiving subpoena can result in spoliation sanctions.]

Core Concept

De-risking = indiscriminate termination of entire categories of customer relationships without individual risk assessment.

Why De-Risking is Problematic:

- Drives legitimate activity into unregulated, informal channels
- Harms financial inclusion (remittance corridors, developing economies)
- Violates risk-based approach (requires individual assessment)
- May contradict regulatory expectations
- Can concentrate risk rather than reduce it
- May violate anti-discrimination laws in some jurisdictions

Key Distinction:

- De-risking (bad): Blanket termination by geography, customer type, or category without individual assessment
- Justified exit (good): Individual, documented termination based on specific risk assessment of that relationship

[RED FLAG: FATF and Wolfsberg guidance explicitly discourages blanket de-risking.]

[SCENARIO] Bank Terminates All African Correspondent Relationships Global bank terminates all correspondent relationships with banks headquartered in Sub-Saharan Africa. Termination applies to all 22 respondent banks, including three that passed recent FATF mutual evaluations with Compliant ratings. Bank conducted no individual risk assessments. Compliance director states: The region is high-risk, so we are exiting entirely.

How to Analyze:

- 1 Blanket termination without individual assessment violates RBA
- 2 Compliant banks terminated along with non-compliant ones
- 3 Drives legitimate activity out of formal system
- 4 FATF and Wolfsberg guidance discourages this
- 5 May harm legitimate remittance and trade flows

[TRAP] Banks have absolute discretion to choose correspondent partners. [CORRECT] RBA requires individual, documented risk assessments. Blanket termination without assessment is de-risking and discouraged.

[SCENARIO] Bank Terminates Specific Respondent After Assessment Bank terminates correspondent relationship with specific respondent after: (1) individual risk assessment; (2) identifying respondent services 14 unlicensed MSBs; (3) issuing two unanswered RFIs; (4) documenting risk assessment and decision. Other banks in same jurisdiction retained.

How to Analyze:

- 1 Individual assessment conducted (not blanket termination)
- 2 Specific risk factors identified
- 3 Attempts to remediate (RFIs) were made
- 4 Decision documented
- 5 Other banks in same jurisdiction retained

[TRAP] Any termination of correspondent relationship is de-risking. [CORRECT] Justified risk-based exit based on individual documented assessment is permissible and NOT de-risking.

FATF's Position on De-Risking

FATF has issued specific guidance addressing the de-risking phenomenon.

FATF Guidance Key Points:

- Broad, categorical termination of entire classes of customers is NOT the preferred risk management strategy under RBA
- Financial institutions should conduct individual, documented risk assessments
- Blanket exclusions based solely on geography or customer type are discouraged
- De-risking can drive activity into unregulated channels, making monitoring harder
- Financial inclusion is a legitimate consideration

Wolfsberg Group Guidance:

- Banks should avoid indiscriminate de-risking
- Where relationship terminated, decision should be documented and risk-based
- Not solely based on commercial considerations
- Attempts to remediate should be made before termination

Regulatory Expectations:

- Terminations will be reviewed for pattern of de-risking
- Banks expected to have documented rationale
- Regulators may question blanket terminations

Core Concept

RFIs are formal requests sent to customers or respondent banks asking for clarification or documentation of suspicious activity.

Best Practices for RFIs:

- Use when you need more information to resolve an alert
- Document the RFI and any response (or lack thereof)
- Do NOT disclose that an investigation or SAR is pending (tipping-off)
- Failure to respond is itself a red flag
- Set reasonable deadline for response (typically 5-10 business days)
- Escalate if no response received
- Maintain copy of RFI in case file

[RED FLAG: Critical: RFIs must be phrased neutrally. Do NOT say we are investigating you for money laundering.]

[SCENARIO] Analyst Tells Customer About AML Flag Compliance analyst calls customer: Our AML system flagged your deposits as potential structuring. We need to know where you are getting all this cash, or we might have to file a report. Customer becomes angry and hangs up.

How to Analyze:

- 1 Mentioning AML system and potential structuring is tipping-off
- 2 Mentioning file a report is explicit tipping-off
- 3 Customer now knows they are under investigation
- 4 RFI was phrased improperly

[TRAP] Analyst was honest with customer, which is good customer service. [CORRECT] RFIs must be neutral. Example: We noticed increase in cash deposits. Can you provide documentation explaining source of funds? No mention of AML or reporting.

Examples of Proper RFI Wording

Neutral language that does not tip off the customer.

Proper Wording Examples:

- We noticed an increase in wire transfers from your account. Please provide documentation explaining the business purpose of these transactions.
- Please confirm the nature of your relationship with [counterparty name] and provide any supporting agreements or invoices.
- Our records show cash deposits totaling [amount] over the past [period]. Please provide documentation supporting the source of these funds.
- Please update your customer profile to reflect recent changes in your business activities.

Documentation Requirements:

- Copy of RFI sent to customer
- Date RFI was sent
- Method of delivery (email, letter, phone log)
- Any response received (or note that no response received)
- Follow-up actions taken
- Escalation if no response

When to Escalate Without RFI:

- Sending RFI would tip off customer (suspicion is very strong)
- Customer has history of destroying records when asked
- Law enforcement requests no contact
- Immediate SAR filing is more appropriate

Core Concept

Training must be tailored to the specific roles and risks of each employee group.

Role-Based Training Requirements:

- Tellers: Cash structuring, CTR triggers, identifying suspicious customer behavior, red flags
- Relationship Managers: PEP identification, EDD requirements, red flags in customer profiles, source of wealth
- Board of Directors: Governance oversight, risk strategy, regulatory expectations, enforcement trends
- IT/Technology: Data security, system controls, audit trail requirements, data quality
- Compliance Staff: Advanced investigation techniques, SAR writing, regulatory updates, emerging typologies
- Senior Management: Program oversight, resource allocation, escalation procedures, regulatory risk
- New Hires: Initial training before any customer contact

[RED FLAG: Deficiency: The same training module delivered to all employees regardless of role.]

[SCENARIO] Bank Delivers Same Training to All 5,000 Employees Bank delivers same two-hour online AML training module to all 5,000 employees: tellers, RMs, Board, IT staff. Training covers technical details of transaction monitoring thresholds. External auditor rates program ineffective because Board does not need threshold calculations, tellers received no cash structuring training.

How to Analyze:

- 1 Tellers need training on cash structuring and CTRs, not model calibration
- 2 Board members need governance training, not technical threshold details
- 3 One-size-fits-all training is ineffective
- 4 Bank must develop role-specific modules

[TRAP] All employees need same training to ensure consistent institutional coverage.
[CORRECT] Training must be tailored to specific roles, responsibilities, and ML/TF risks.
Regulators expect role-based training.

[SCENARIO] Board Training Covers CTR Filing and Alert Review Bank's annual Board AML training covers: (1) how to identify suspicious transactions in alerts; (2) how to file Currency Transaction Reports; (3) AML risk appetite and governance oversight; (4) regulatory expectations for Board oversight.

How to Analyze:

- ❶ Board members do NOT file CTRs or review alerts (operational)
- ❷ Board training should cover risk appetite, governance, oversight
- ❸ Items 1 and 2 are inappropriate for Board training
- ❹ Items 3 and 4 are appropriate for Board training

[TRAP] Board members need to understand all aspects of AML program, including operations. [CORRECT] Board training should focus on governance, oversight, risk strategy, and regulatory expectations, not operational tasks.

Training Frequency Requirements

Initial training AND periodic refresher training are required.

Frequency Requirements:

- New hire training: Before any customer contact or within 30 days of hire
- Annual refresher training: At least once per calendar year
- Role change training: When employee moves to new position with different risks
- Policy change training: When material changes to AML program occur
- Remedial training: For employees who fail testing or make errors
- Regulatory update training: As needed when new regulations issued

Documentation Requirements:

- Training attendance records (who attended)
- Training content (what was covered, slides, materials)
- Training dates and duration
- Testing results (if applicable)
- Certificates of completion
- Records of remedial training
- Retention: Minimum 5 years

Training Effectiveness Assessment:

- Pre- and post-training testing
- Scenario-based testing
- Observations of employee behavior
- Audit of training program
- Tracking of repeated errors

[RED FLAG: Training without effectiveness assessment may not satisfy regulatory requirements.]

Core Concept

Laws protect employees who report AML violations from retaliation.

Key Protections (United States):

- Bank Secrecy Act (31 U.S.C. Section 5328) prohibits retaliation for reporting BSA violations
- Dodd-Frank Act Section 922 (SEC-related disclosures)
- FIRREA (financial institution anti-retaliation)
- Sarbanes-Oxley Act (public company whistleblowers)
- State law protections (varies by jurisdiction)

What Constitutes Retaliation:

- Termination or firing
- Demotion or reduction in responsibilities
- Suspension without pay
- Harassment or hostile work environment
- Negative performance reviews (PIPs) without prior issues
- Exclusion from meetings or opportunities
- Transfer to undesirable location
- Blacklisting within industry

[RED FLAG: Retaliation can result in significant damages, reinstatement, and legal fees for bank.]

[SCENARIO] Analyst Receives PIP After Internal Report Compliance analyst reports internally that senior management is suppressing SAR filings on high-revenue corporate client. Three weeks later, analyst receives performance improvement plan citing communication issues - her first negative review in eight years. She believes PIP is retaliatory.

How to Analyze:

- 1 Timing (3 weeks after report) suggests retaliation
- 2 First negative review in 8 years is suspicious
- 3 BSA prohibits retaliation for reporting BSA violations
- 4 She can file complaint with DOL/OSHA within 180 days
- 5 Internal reports are protected, not just external

[TRAP] Internal reports are not protected; only external reports to FinCEN are protected.
[CORRECT] BSA prohibits retaliation for internal reports as well. Document everything and file complaint with DOL/OSHA.

Whistleblower Complaint Process

Employees have specific channels to file retaliation complaints.

Filing a Complaint (United States):

- File with Department of Labor, Occupational Safety and Health Administration (OSHA)
- Deadline: Within 180 days of the adverse employment action
- No filing fee
- Can file anonymously or with attorney representation
- OSHA investigates and can order reinstatement, back pay, and damages
- If OSHA does not act, employee can take case to federal court

What to Document:

- Copy of original report (with date)
- Any evidence of retaliation (PIP, emails, witness statements)
- Performance reviews before and after report
- Timeline of events
- Any communications with management about the report

Protection from Retaliation:

- Bank cannot retaliate for filing complaint
- Additional remedies available if bank retaliates against whistleblower complaint
- Whistleblower can recover legal fees if successful

[RED FLAG: Employers cannot require employees to sign confidentiality agreements waiving whistleblower rights.]

Core Concept

AML compliance does not operate in isolation. Other departments enable effective AFC programs.

Key Supporting Functions and Their Roles:

- Data Privacy: Ensures customer data protected while enabling lawful information sharing
- Cybersecurity: Protects AML systems from attack; identifies cyber-related red flags (ransomware, unauthorized access)
- IT/Technology: Maintains transaction monitoring systems, data feeds, audit trails, system availability
- Human Resources: Employee due diligence, insider threat monitoring, background checks
- Vendor Management: Third-party due diligence for outsourced AML functions
- Legal: Advice on regulatory requirements, subpoena response, legal hold management
- Internal Audit: Independent testing of AML controls (Third Line)
- Risk Management: Enterprise risk assessment integration

[RED FLAG: AML cannot function effectively without strong support from these departments.]

[SCENARIO] Bank Receives GDPR Right to Erasure Request European bank receives GDPR right to erasure request from customer demanding deletion of all personal data, including KYC documents and transaction records. Customer was subject of SAR filed 18 months ago. Data Privacy Officer argues GDPR requires deletion. AML Officer argues AML recordkeeping requires retention.

How to Analyze:

- 1 GDPR Article 17(3) exempts data retention required by law
- 2 AML recordkeeping (minimum 5 years) is legal obligation
- 3 Bank can lawfully refuse to delete AML-required records
- 4 SAR confidentiality also prohibits acknowledging SAR to customer

[TRAP] GDPR right to erasure is absolute and overrides all other laws. [CORRECT] AML retention requirements are legal exception to GDPR erasure. Bank may refuse deletion for records required to retain.

[SCENARIO] Customer Pays Ransom to SDN-Listed Wallet Cybersecurity team detects corporate customer's systems compromised by ransomware. Customer pays ransom in Bitcoin to wallet address appearing on OFAC SDN list. Cybersecurity team notifies AML team.

How to Analyze:

- 1 Paying ransom to SDN-listed wallet is OFAC violation
- 2 Transaction may also constitute money laundering
- 3 Bank should file SAR
- 4 Bank should consider whether to block transaction
- 5 AML and cybersecurity must coordinate

[TRAP] Bank should process payment to avoid harm to customer. [CORRECT] AML and cybersecurity teams must coordinate. Paying ransom to SDN-listed wallet requires sanctions review and potential SAR.

IT's Role in AML Compliance

IT maintains the systems that enable AML monitoring. Failures become compliance failures.

IT Responsibilities for AML:

- System availability (monitoring must run 24/7/365)
- Data integrity (no corruption, accurate processing)
- Audit trails (who accessed what, when, from where)
- Change management (documented approvals for system changes)
- Disaster recovery (backup systems, recovery time objectives)
- Security (access controls, preventing unauthorized changes)
- Performance (system processes alerts within required timeframes)

Common IT Failures with AML Impact:

- System outages during critical monitoring windows
- Data feed failures without alerting
- Unauthorized changes to thresholds or scenarios
- Loss of audit trail data
- Slow performance causing alert backlog
- Security breach allowing manipulation

[RED FLAG: IT failures are compliance failures when they impact AML monitoring effectiveness.]

Core Concept

Insider threats (employees misusing their access) are a significant AML risk.

Key Controls for Insider Threat Management:

- Background checks on hiring (criminal, credit, employment verification)
- Ongoing employee monitoring (not just customer monitoring)
- Segregation of duties (no single employee controls end-to-end)
- Access controls and audit trails (who accessed what)
- Mandatory vacation policies (detect ongoing fraud)
- Job rotation for sensitive positions
- Employee hotline for reporting suspicious colleagues
- Monitoring for lifestyle changes (where permitted by law)

[RED FLAG: Red flags: Employee living beyond means, refusing vacation, accessing accounts outside job scope, multiple overrides.]

[SCENARIO] RM Overrides 23 Alerts for Same Client AML analyst notices senior RM has overridden 23 transaction monitoring alerts in past year for same corporate client. Each override note states: Client is legitimate. RM has override access without supervisory approval. RM recently purchased new luxury car and vacation home.

How to Analyze:

- 1 23 overrides for same client is unusual
- 2 No supervisory approval for overrides is control weakness
- 3 Lifestyle changes may indicate illicit enrichment
- 4 Bank should investigate RM
- 5 Overrides should require supervisor approval
- 6 Pattern suggests RM may be compromised

[TRAP] RM has authority to override alerts; no violation. [CORRECT] Multiple overrides for same client plus lifestyle changes require investigation. Overrides should require supervisory approval.

Why Mandatory Vacation Detects Fraud

Employees committing fraud often avoid taking vacation to prevent detection.

How Mandatory Vacation Works as Control:

- Employee must take consecutive days off (typically 5-10 business days)
- Another employee performs their duties during absence
- Substitute may discover irregularities that employee was hiding
- Employee cannot cover up ongoing fraud while absent
- Common in financial institutions for high-risk roles

Roles Where Mandatory Vacation is Critical:

- Wire transfer processors
- Account opening staff
- Transaction monitoring override approvers
- Suspense account managers
- Reconciliation staff
- Customer data maintenance

Red Flags Related to Vacation:

- Employee never takes vacation
- Employee cancels vacation at last minute repeatedly
- Employee works during vacation
- Employee refuses to provide passwords for coverage
- Employee becomes anxious when vacation discussed

[RED FLAG: Employees who never take vacation should be subject to enhanced scrutiny.]

Core Concept

Relationship managers (First Line) and compliance (Second Line) have complementary but distinct roles.

RM Responsibilities (First Line):

- Know your customer (KYC) at onboarding
- Identify and report unusual activity to compliance
- Respond to RFIs from compliance
- Update customer information when changes occur
- Provide context on customer's legitimate business
- NOT make SAR filing decisions

Compliance Responsibilities (Second Line):

- Investigate suspicious activity independently
- Make SAR filing decisions (RMs do NOT decide)
- Escalate material findings to management and Board
- Cannot be overridden by RM for commercial reasons
- Must maintain independence from revenue pressure

[RED FLAG: Critical: RMs cannot veto or prevent SAR filings based on commercial importance of client.]

[SCENARIO] RM Argues Against SAR Due to Client Revenue Compliance analyst concludes reasonable suspicion of money laundering on high-revenue corporate client generating \$5 million annual fees. RM argues: This client is too important. We cannot file a SAR based on suspicion. Get more evidence first. CCO under pressure from RM delays filing.

How to Analyze:

- 1 Reasonable suspicion is legal standard for SAR
- 2 Commercial importance is NOT valid reason to delay or avoid filing
- 3 CCO has independent obligation to file
- 4 Delaying filing is regulatory violation
- 5 RM attempting to improperly influence compliance

[TRAP] RM commercial concern is legitimate and should be considered. [CORRECT]
Compliance decisions on SAR filing must be independent of commercial considerations. CCO must file upon reasonable suspicion regardless of client revenue.

Healthy RM-Compliance Relationship

When functioning properly, RM and compliance work together while maintaining appropriate separation.

RM Should Provide:

- Context about customer's legitimate business
- Explanation of unusual transactions if available
- Documentation supporting legitimate activity
- Updated customer information
- Early warning of potential red flags

RM Should NOT Do:

- Pressure compliance to close alerts
- Threaten to escalate to senior management to override compliance
- Withhold information that might lead to SAR
- Discuss SAR filing with customer
- Make independent determination of suspicious activity

Compliance Should Provide:

- Clear guidance on what constitutes suspicious activity
- Training on red flags
- Timely response to RM inquiries
- Feedback on SAR outcomes (where permitted)
- Respect for legitimate customer relationships

[RED FLAG: If RM is pressuring compliance to avoid SAR filing, escalate to higher authority.]

Core Concept

Banks remain responsible for outsourced AML functions. Vendor risk must be managed.

Key Requirements for Vendor Management:

- Due diligence on vendors before engagement
- Contractual obligations for AML compliance
- Right to audit vendor performance
- Ongoing monitoring of vendor effectiveness
- Bank retains ultimate regulatory responsibility
- Cannot outsource accountability

Vendors Requiring AML Due Diligence:

- Transaction monitoring system providers
- Sanctions screening vendors
- KYC/CIP verification services
- Customer identification document vendors
- Case management system providers
- Training providers
- Independent testing firms

[RED FLAG: Cannot outsource responsibility: Even if vendor performs AML functions, bank is still accountable to regulators.]

[SCENARIO] Vendor System Fails for 8 Months Bank outsources transaction monitoring to third-party vendor. Vendor system fails to generate alerts for 8 months due to technical error. Bank's internal compliance team did not perform any validation of vendor outputs. When discovered, vendor claims liability. Bank argues vendor is responsible.

How to Analyze:

- 1 Bank is ultimately responsible to regulators
- 2 Bank cannot delegate liability to vendor
- 3 Bank should have performed validation and reconciliation
- 4 Bank must remediate (review missed period, file SARs)
- 5 Bank must address vendor oversight failure

[TRAP] Vendor contract makes them liable for monitoring failures. [CORRECT] Bank retains regulatory responsibility regardless of vendor contracts. Bank must have vendor oversight and validation controls.

Pre-Engagement and Ongoing Vendor Diligence

Comprehensive due diligence required before and during vendor relationship.

Pre-Engagement Due Diligence:

- Vendor background and reputation
- Financial stability of vendor
- Vendor's own AML program
- Vendor's data security practices
- Vendor's subcontractor relationships
- References from other bank clients
- Regulatory history (any enforcement actions)
- Business continuity and disaster recovery

Contract Requirements:

- Right to audit vendor (on-site and remote)
- Service level agreements (uptime, accuracy)
- Data ownership and return provisions
- Breach notification requirements
- Subcontractor approval rights
- Liability and indemnification provisions
- Termination rights for non-performance
- Confidentiality and data protection

Ongoing Monitoring:

- Regular performance reviews
- Service level monitoring
- Annual vendor risk assessment
- Periodic on-site audits
- Vendor security assessment updates

Core Concept

When a customer poses unacceptable risk, bank must escalate through governance and potentially offboard.

Escalation Path for High-Risk Customers:

- 1 Analyst identifies suspicious activity
- 2 Investigation conducted and documented
- 3 If SAR filed, notify AML committee
- 4 If multiple SARs or high risk, escalate to senior management
- 5 Board notification for material risks
- 6 Decision to offboard requires senior management approval
- 7 Offboarding executed according to procedures

Documentation Required for Escalation:

- Summary of suspicious activity
- Investigation findings
- SARs filed (if any)
- Risk assessment of relationship
- Attempts to remediate (RFIs, enhanced monitoring)
- Recommendation (close or continue)
- Approval documentation

[RED FLAG: Offboarding must be documented and risk-based, not retaliatory or discriminatory.]

[SCENARIO] Bank Has Filed 7 SARs on Account Over 14 Months Bank filed 7 SARs on account over 14 months. Account shows clear patterns of structured deposits followed by wires to offshore shell companies. Compliance committee recommends offboarding. RM argues: No conviction has occurred. Client is innocent until proven guilty. We should keep the account.

How to Analyze:

- 1 Banks are not courts of law
- 2 Standard for offboarding is risk, not conviction
- 3 7 SARs on one account is clear evidence of elevated risk
- 4 Bank can (and often should) offboard
- 5 RM argument confuses criminal standard with risk management

[TRAP] Customer is innocent until proven guilty, so bank should keep account. [CORRECT]
Offboarding is risk management decision, not criminal conviction. Multiple SARs justify offboarding regardless of conviction status.

Proper Offboarding Execution

Offboarding must be done carefully to avoid legal and reputational risk.

Offboarding Steps:

- 1 Document decision to offboard with rationale
- 2 Obtain required approvals (compliance committee, senior management)
- 3 Notify law enforcement if ongoing investigation
- 4 Provide notice to customer (standard account closure notice)
- 5 Do NOT disclose reason if related to SAR (tipping-off)
- 6 Return any remaining funds to customer
- 7 File SAR if closure itself is suspicious
- 8 Maintain records of offboarding decision

What NOT to Do When Offboarding:

- Do not tell customer we are closing account because of SAR
- Do not close account to retaliate against whistleblower customer
- Do not close account without documentation
- Do not delay returning customer funds
- Do not offboard solely based on protected characteristics

Alternative to Full Offboarding:

- Restrict account activity (no wires, no new deposits)
- Enhanced monitoring
- Lower transaction limits
- Require prior approval for certain transactions
- Convert to cash management only

[RED FLAG: If law enforcement requests account remain open, document and comply.]

- 1 Three Lines: First=Business, Second=Compliance, Third=Audit
- 2 Independence: Audit cannot design controls it later tests
- 3 Board approves program, CCO implements
- 4 False negatives worse than false positives
- 5 Over-filtering raises false negatives
- 6 Model drift requires recalibration
- 7 Silent data failure = monitoring gap
- 8 Alert adjudication must be documented
- 9 SAR standard = reasonable suspicion
- 10 Tipping-off includes disclosing investigation
- 11 314(b) is exception to tipping-off
- 12 Comply with subpoenas, do not notify customer
- 13 Keep open requests: document, approve, comply
- 14 De-risking = blanket termination (bad)
- 15 Justified exit = individual assessment (good)
- 16 RFLs must be neutral phrasing
- 17 Training must be role-based
- 18 Whistleblower protections exist for internal reports
- 19 Vendor oversight: bank retains responsibility
- 20 Offboarding is risk decision, not conviction
- 21 Insider threats: monitor employees
- 22 Mandatory vacation detects fraud
- 23 RMs cannot block SARs for commercial reasons
- 24 GDPR has AML retention exception
- 25 Cybersecurity and AML coordinate on ransomware
- 26 Data reconciliation prevents silent failures
- 27 QA reviews ensure analyst consistency
- 28 Legal hold required after subpoena
- 29 FATF discourages blanket de-risking
- 30 Board must be informed of material deficiencies

- Audit designing controls → Independence violation
- RM closing alerts → First Line overstepping
- No documentation in case files → Unverifiable
- 77 percent false negative rate → Material deficiency
- 34 percent missing data for 14 months → Data failure
- Teller says compliance reviewing → Tipping-off
- Blanket termination of African banks → De-risking
- RM blocks SAR for revenue → Improper pressure
- Same training for Board and tellers → Ineffective
- PIP 3 weeks after internal report → Retaliation
- Employee override without approval → Insider risk
- Offboarding delayed for more evidence → Misunderstanding
- CCO approves own policy → Board approval missing
- Management hides deficiency from Board → Violation
- Vendor failure with no oversight → Outsourcing failure
- Analyst assumes cash is normal → No investigation
- Different analysts different rates → No standards
- Thresholds raised 250 percent arbitrary → Over-filtering
- Never recalibrated model → Model drift
- No reconciliation controls → Data gap undetected

- Domain 6 is 30 percent of exam - second largest domain
- Three Lines of Defense is foundational - know who does what
- Independence is critical - audit cannot audit its own work
- SAR standard = reasonable suspicion, not proof
- Tipping-off includes disclosing investigation exists
- False negatives are worse than false positives
- De-risking = blanket termination (bad); justified exit = individual assessment (good)
- Training must be role-based
- Whistleblower protections exist for internal and external reports
- Banks cannot outsource regulatory responsibility to vendors
- Offboarding is risk decision, not conviction
- RMs cannot override compliance SAR decisions
- Board must approve AML program
- Material deficiencies must be reported to Board
- RFIs must be neutral - cannot mention AML or filing
- 314(b) sharing is permitted and not tipping-off
- Legal hold required after subpoena
- Data reconciliation prevents silent feed failures
- QA ensures analyst consistency
- Mandatory vacation detects insider fraud